

CII Cybersecurity Due Diligence & Vendor Management Manual

Pre-Amendment Baseline Version

Important scope note: This manual establishes a practical due-diligence and vendor-management framework for organisations operating designated CII. It focuses on the pre-amendment CII framework and does not incorporate later regulatory categories.

1. Vendor Risk Assessment

- Identify vendors with access to CII, sensitive systems or operationally critical services.
- Assess the vendor's security governance, access controls, incident response, vulnerability management and business continuity arrangements.
- Classify vendors according to criticality and cybersecurity risk.

2. Pre-Contract Checklist

- Confirm the vendor's security responsibilities.
- Assess security certifications or independent assurance where appropriate.
- Review incident notification arrangements.
- Review subcontracting and privileged-access arrangements.
- Assess business continuity and disaster-recovery capabilities.

3. Contractual Controls

- Include confidentiality and security obligations appropriate to the relationship.
- Address incident notification and cooperation.
- Define access-control requirements.
- Provide appropriate audit, assurance or information rights.
- Address return, deletion or protection of information at the end of the relationship.

4. Ongoing Monitoring

- Review material vendors periodically.
- Track material security incidents and unresolved security findings.
- Reassess vendors after major changes to systems, services or risk profile.

5. Vendor Incident Workflow

- Receive and record vendor notification.
- Determine whether CII or essential services may be affected.
- Escalate to cybersecurity, legal and compliance personnel.
- Assess applicable reporting obligations.
- Coordinate containment, remediation and evidence preservation.
- Record closure and lessons learned.

6. Vendor Review Checklist

- Vendor identified and risk-rated
- Security responsibilities documented
- Incident notification clause reviewed
- Access controls reviewed
- Business continuity assessed
- Subcontracting assessed
- Periodic review date assigned
- Material findings remediated or accepted

Document control

Version: 1.0

Status: Illustrative pre-amendment baseline

Owner: Legal / Compliance / Cybersecurity

Review cycle: Annual or upon material regulatory change